

# **Tema 4.**

# **Principios del buen gobierno y ética empresarial**

# Contenidos

- Principios de buen Gobierno IT: Cobit 5
- Compliance Officer: funciones y responsabilidades
- Relaciones con terceras partes dentro del Compliance
- CISO, competencias y responsabilidades

# Contenidos

- **Principios de buen Gobierno IT: Cobit 5**
- Compliance Officer: funciones y responsabilidades
- Relaciones con terceras partes dentro del Compliance
- CISO, competencias y responsabilidades

# LOS 5 PRINCIPIOS DE COBIT



- El marco y los componentes de COBIT 5 — aplicados a la ciberseguridad — cubren el gobierno, la gestión y el aseguramiento. Para asegurar el gobierno adecuado y exhaustivo se deben usar los cinco principios básicos de COBIT 5 como punto de partida.

# LOS 5 PRINCIPIOS DE COBIT

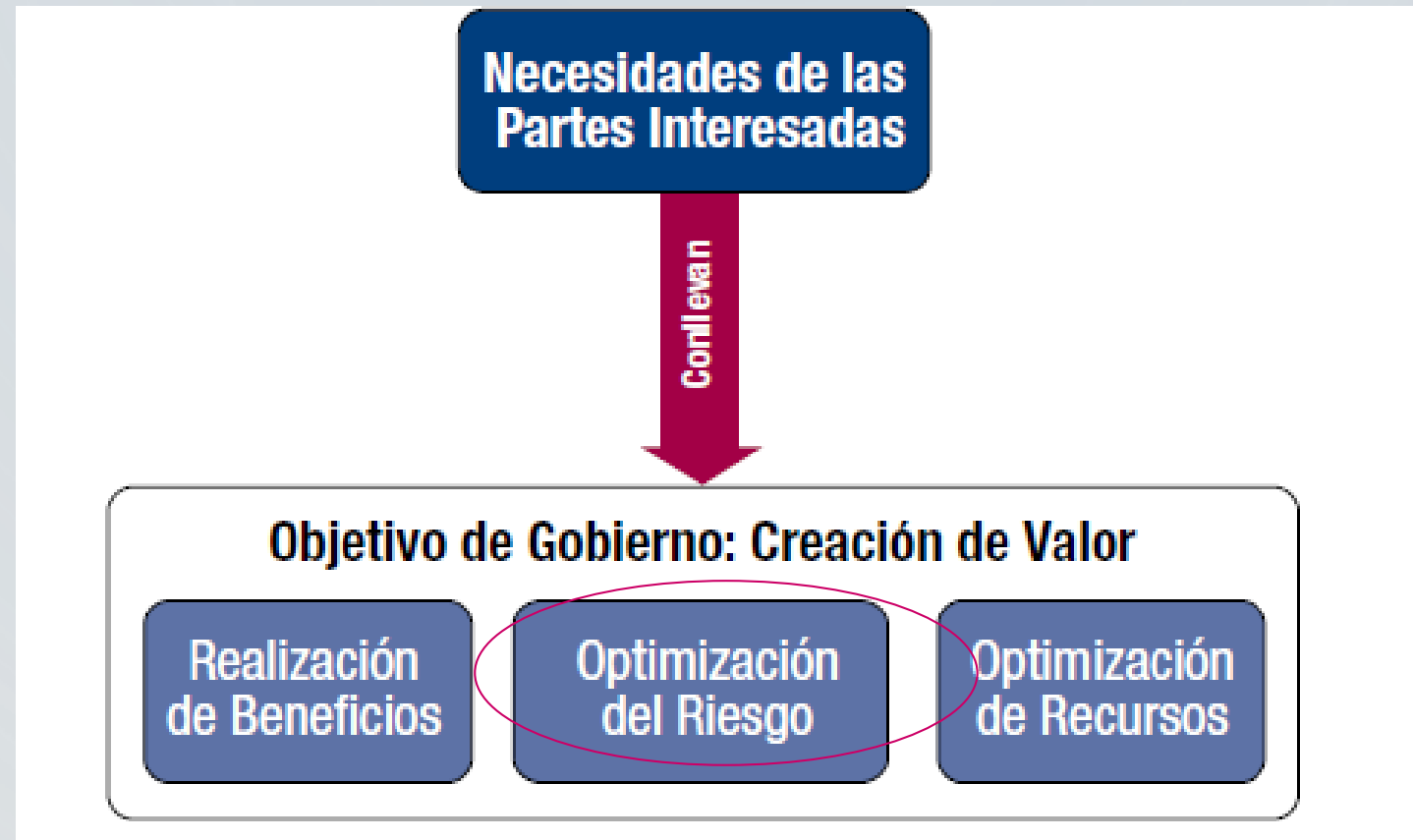
Para crear un marco único integrado para gobernar (y gestionar) la ciberseguridad es necesario tener en cuenta otras disposiciones de gobierno dentro de la empresa:



# 1. SATISFACER LAS NECESIDADES DE LAS PARTES INTERESADAS

- **Principio 1: Satisfacer las necesidades de las partes interesadas**

- ☐ Las compañías existen para crear valor para sus partes interesadas





# 1. SATISFACER LAS NECESIDADES DE LAS PARTES INTERESADAS

## •Principio 1: Satisfacer las necesidades de las partes interesadas

- ☐ Las organizaciones tienen muchas partes interesadas
- ☐ El sistema de gobierno deberá considerar a todas las partes interesadas al tomar decisiones con respecto a la evaluación de riesgos, los beneficios y el manejo de recursos.
- ☐ Para cada decisión se puede, y se debe, hacer las siguientes preguntas:
  - ☐ ¿Quién recibe los beneficios?
  - ☐ ¿Quién asume el riesgo?
  - ☐ ¿Qué recursos se necesitan?

# 1. SATISFACER LAS NECESIDADES DE LAS PARTES INTERESADAS

- **Principio 1: Satisfacer las necesidades de las partes interesadas**





# 1. SATISFACER LAS NECESIDADES DE LAS PARTES INTERESADAS

- **Principio 1: Satisfacer las necesidades de las partes interesadas**

- Los beneficios de las Metas en Cascada de COBIT 5:

- ☐ Permite definir las prioridades para implementar, mejorar y asegurar el gobierno corporativo de la TI

- ☐ Metas en cascada:

- ☐ Definen los objetivos y las metas tangibles y relevantes

- ☐ Filtran la base de conocimiento

- ☐ Claramente identifican y comunican qué importancia tienen los catalizadores

## 2. CUBRIR LA EMPRESA EXTREMO-A-EXTREMO

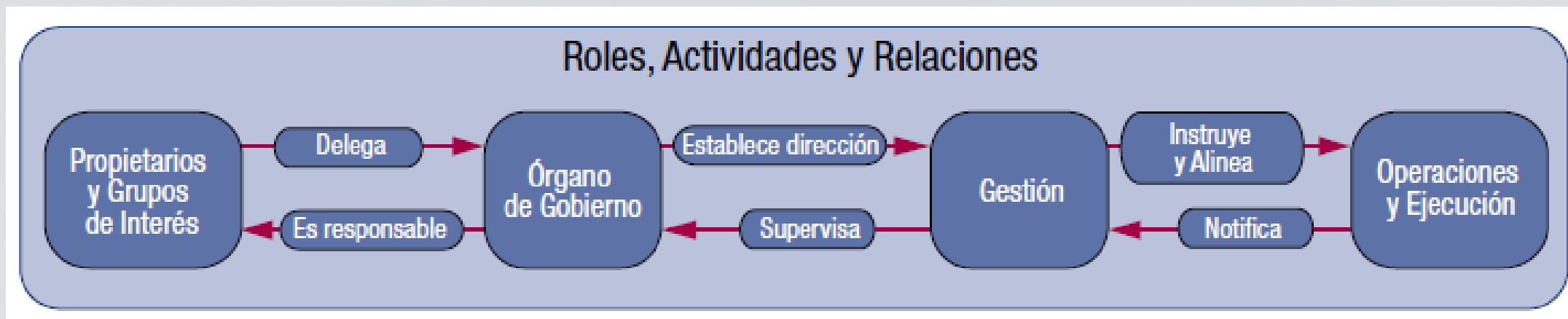
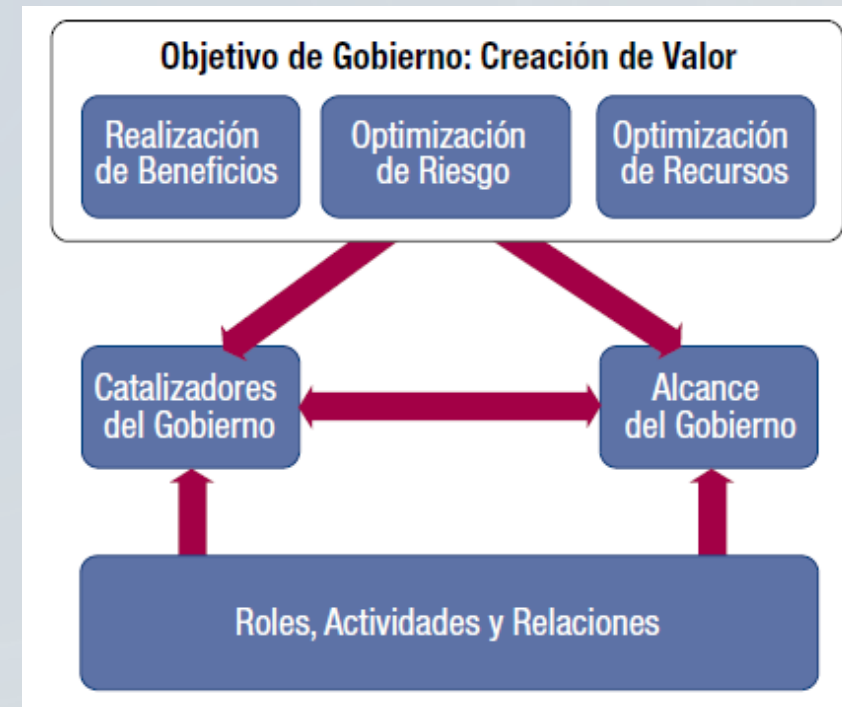
- **Principio 2: Cubrir la empresa de Extremo-a-Extremo**

- ☐ COBIT 5 se concentra en el gobierno y la Gestión de la tecnología de la información y relacionadas
- ☐ COBIT 5 Integra el gobierno de la TI corporativa en el gobierno corporativo
- ☐ COBIT 5 Cubre todas las funciones y los procesos dentro de la organización

## 2. CUBRIR LA COMPAÑÍA DE FORMA INTEGRAL

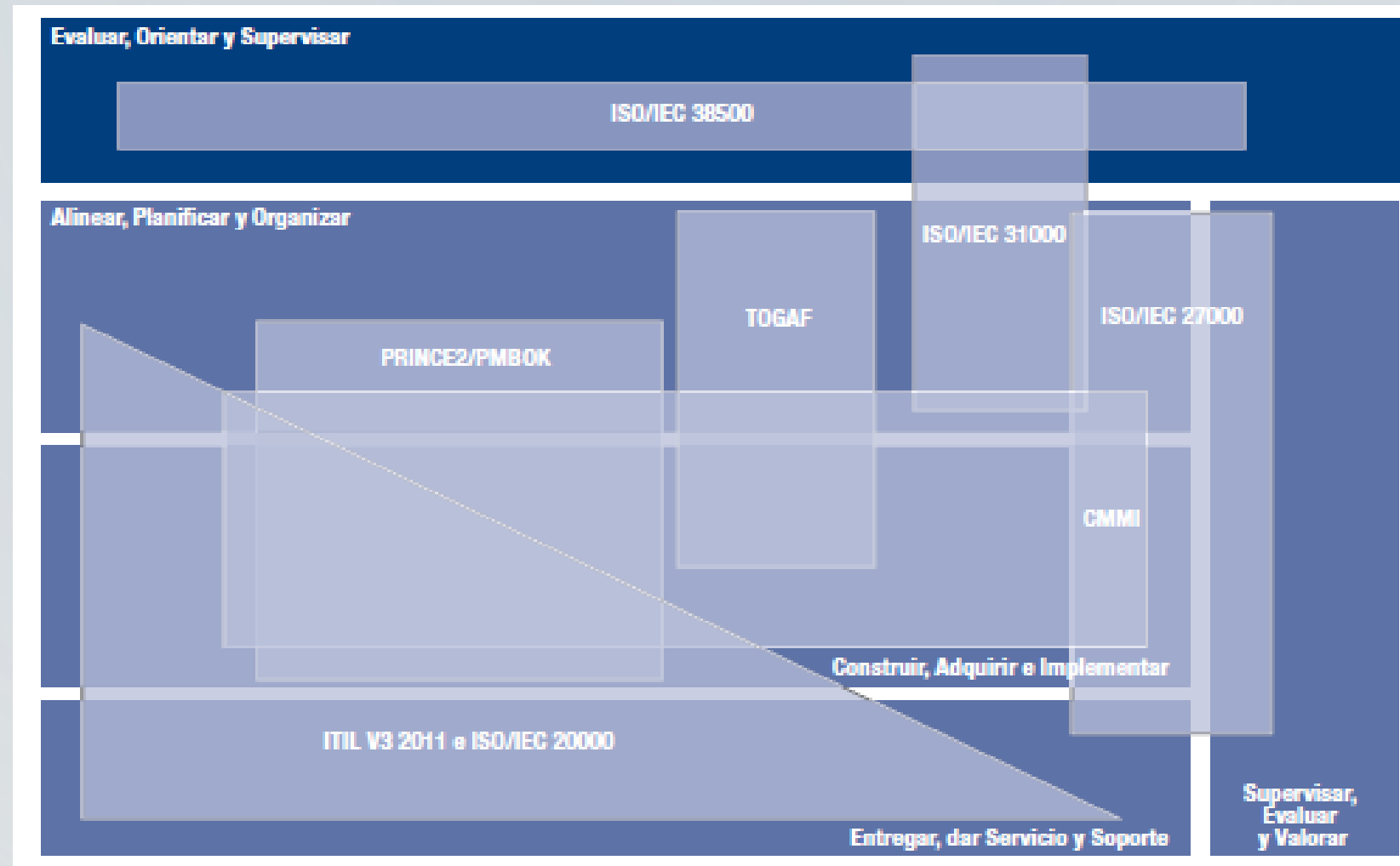
- Principio 2: Cubrir la compañía de forma integral

Los componentes claves  
de un sistema de  
gobierno



### 3. APLICAR UN ÚNICO MARCO INTEGRADO

- Principio 3: Aplicar un único marco integrado



## 4. HABILITAR UN ENFOQUE HOLÍSTICO

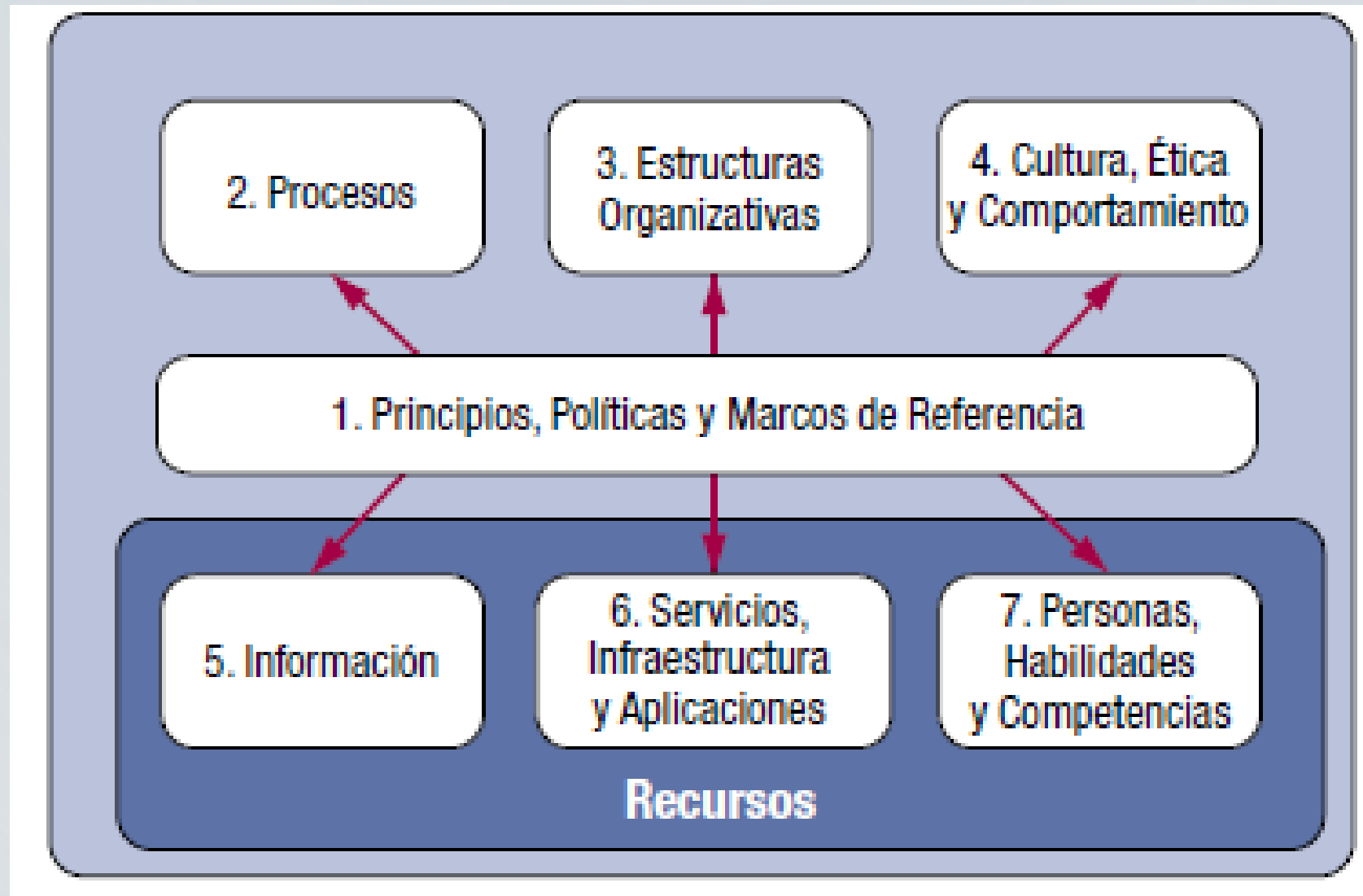
### •Principio 4: Habilitar un enfoque holístico

Los catalizadores de COBIT 5 son:

- ☐ Factores que, individual y colectivamente, influyen sobre si algo funcionará, en el caso de COBIT, Gobierno y Gestión sobre la TI corporativa.
- ☐ Impulsados por las metas en cascada: las metas de alto nivel relacionadas con la TI definen qué deberían lograr los diferentes catalizadores.
- ☐ Descritos por el marco de COBIT 5 en siete categorías.

## 4. HABILITAR UN ENFOQUE HOLÍSTICO

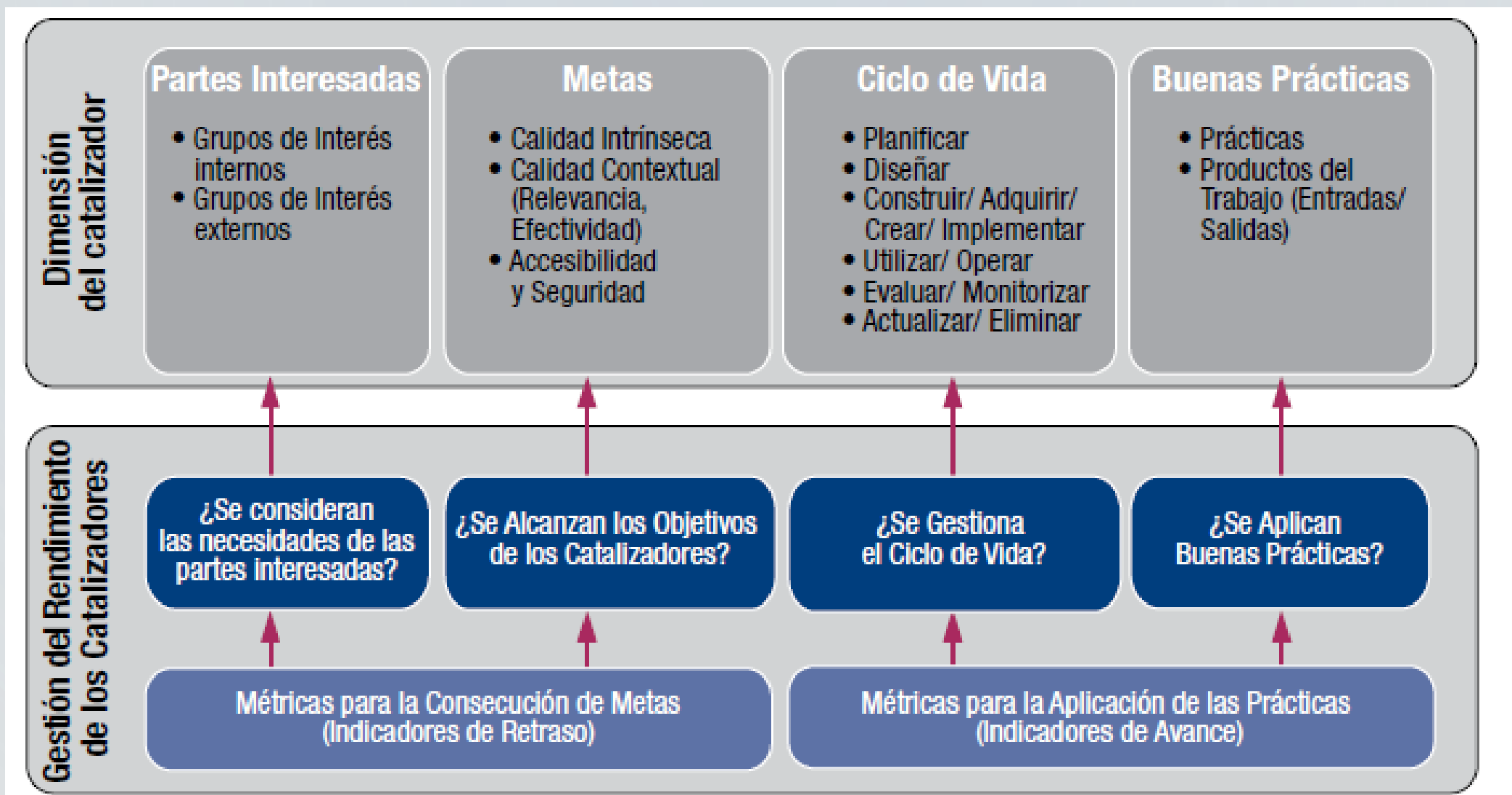
- Principio 4: Habilitar un enfoque holístico





## 4. HABILITAR UN ENFOQUE HOLÍSTICO

### • Principio 4: Habilitar un enfoque holístico



## 4.1 PRINCIPIOS, POLÍTICAS Y MARCOS DE REFERENCIA

### ❏ Principios de Seguridad de la Información

- Foco en el negocio.
- Entregar calidad y valor a las partes interesadas.
- Cumplir con los requisitos legales y regulatorios relevantes.
- Evaluar las amenazas de información actuales y futuras.
- Promocionar la mejora continua en seguridad de la información.
- Adoptar un enfoque basado en el riesgo.
- Proteger la información clasificada.
- Concentrarse en aplicaciones críticas de negocio.
- Desarrollar sistemas de forma segura.
- Actuar de manera profesional y ética.
- Fomentar una cultura positiva de seguridad de la información.

## 4.1 PRINCIPIOS, POLÍTICAS Y MARCOS DE REFERENCIA

- Política de Seguridad de la Información



## 4.2 PROCESOS

### □ Procesos de gestión de la Seguridad

| Procesos COBIT 5                               | Procesos de Gestión de la Ciberseguridad                                                                                                              |
|------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| APO01 Gestionar el marco de gestión de TI.     | Integrar la ciberseguridad en el marco de gestión de TI.                                                                                              |
| APO02 Gestionar la estrategia.                 | Alinear la estrategia de ciberseguridad con la estrategia general de seguridad de la información.                                                     |
| APO03 Administrar la arquitectura empresarial. | Definir e integrar los componentes de arquitectura de ciberseguridad como parte de la arquitectura general en materia de seguridad de la información. |
| APO05 Gestionar la cartera.                    | Proceso subsidiario para identificar y obtener fondos para la gestión de la ciberseguridad.                                                           |
| APO06 Gestionar el presupuesto y los costes.   | Presupuesto subsidiario para ciberseguridad, incluyendo la financiación de contingencia para situaciones reales de ataque/violación de seguridad.     |
| APO07 Gestionar los recursos humanos.          | Proceso subsidiario para formar en ciberseguridad a usuarios y personal de TI.                                                                        |
| APO09 Gestionar los acuerdos de servicio.      | Proceso para ANSs y acuerdos de nivel operativo (OLAs) de ciberseguridad en línea con el escenario general de gobierno seleccionado.                  |
| APO10 Gestionar los proveedores.               | Elementos de proceso añadidos para la gestión de proveedores y terceros en materia de ciberseguridad.                                                 |

## 4.2 PROCESOS

### ❏ Procesos de gestión de la Seguridad

| Procesos COBIT 5                                                   | Procesos de Gestión de la Ciberseguridad                                                                                                                                                 |
|--------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| AP012 Gestionar el riesgo.                                         | Proceso subsidiario para identificación, evaluación y tratamiento de riesgos de ciberseguridad.                                                                                          |
| AP013 Gestionar la seguridad.                                      | Integrar la ciberseguridad como parte del SGSI.                                                                                                                                          |
| BAI02 Gestionar la definición de requisitos.                       | Proceso subsidiario para definir requerimientos de ciberseguridad.                                                                                                                       |
| BAI03 Gestionar la identificación y la construcción de soluciones. | Proceso subsidiario para identificar soluciones específicas en materia de ciberseguridad.                                                                                                |
| BAI05 Gestionar la habilitación del cambio organizativo.           | Vincular con la transformación de la ciberseguridad, e integrar los pasos de transformación dentro de la gestión del cambio en general.                                                  |
| BAI06 Gestionar los cambios.                                       | Proceso subsidiario para cambios y cambios de emergencia en ciberseguridad.                                                                                                              |
| BAI07 Gestionar la aceptación del cambio y de la transición.       | Vincular con la transformación de la ciberseguridad, e integrar los pasos de transformación dentro del cambio general.                                                                   |
| BAI08 Gestionar el conocimiento.                                   | Proceso subsidiario de gestión del conocimiento para ciberseguridad.                                                                                                                     |
| DSS01 Gestionar las operaciones.                                   | Proceso subsidiario de operaciones para ciberseguridad, relacionado con las operaciones generales de TI, incluyendo servicios externalizados y supervisión de infraestructuras críticas. |
| DSS02 Gestionar las peticiones y los incidentes de servicio.       | Proceso subsidiario de ciberseguridad para identificar, clasificar, escalar y gestionar incidentes relacionados.                                                                         |
| DSS03 Gestionar los problemas.                                     | Proceso subsidiario de ciberseguridad para identificar causas raíz, prevenir la recurrencia y recomendar mejoras.                                                                        |



## 4.3 ESTRUCTURAS ORGANIZATIVAS

### ☐ Gestor de Seguridad de la Información

| Área                                    | Característica                                                                                                                                                                                                             |
|-----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Mandato                                 | Responsabilidad general de los esfuerzos de gestión de la seguridad de la información                                                                                                                                      |
| Principios Operativos                   | Informa al CISO (o, en algunas empresas, a los responsables de la unidades de negocio)                                                                                                                                     |
| Ámbito de Control                       | Seguridad de la información de aplicaciones, seguridad de la información de infraestructuras, gestión de accesos, gestión de amenazas, gestión de riesgos, programa de concienciación, métricas, evaluación de proveedores |
| Nivel de autoridad/derechos de decisión | Autoridad general en la toma de decisiones en el dominio de las prácticas de seguridad de la información.                                                                                                                  |
| Derechos de delegación                  | No debe delegar la toma de decisiones relacionadas con el dominio de la práctica de la seguridad de la información.                                                                                                        |
| Ruta de escalado                        | Las cuestiones se escalan al CISO                                                                                                                                                                                          |
| Ciberseguridad                          | Responsabilidad de que se haga; responsabilidad en las pequeñas y medianas empresas, delegación a expertos en empresas de mayor tamaño.                                                                                    |

## 4.4 CULTURA, ÉTICA Y COMPORTAMIENTO

### •Modelo de comportamiento de COBIT 5

| Modelo de Comportamiento de COBIT 5                                                                                                                                                                         | Aplicación a la Ciberseguridad                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| La seguridad de la información se ejercita en las operaciones cotidianas.                                                                                                                                   | <ul style="list-style-type: none"><li>• Los principios y prácticas de ciberseguridad se aplican en las operaciones cotidianas.</li><li>• Todos los socios comprenden y aplican por completo y en el momento oportuno las medidas de ciberseguridad.</li></ul>                                                                                                                                                                                                                                                                          |
| Las personas respetan la importancia de los principios y políticas de seguridad de la información.                                                                                                          | <ul style="list-style-type: none"><li>• Todos los usuarios entienden las prioridades definidas en ciberseguridad y cómo aplicarlas en su entorno de TI personal y de negocio.</li><li>• Todos los usuarios son conscientes, e idealmente están involucrados, en la definición de las políticas y principios de ciberseguridad.</li><li>• Se actualizan frecuentemente los principios, políticas, estándares y procedimientos de operación críticos de ciberseguridad para reflejar la realidad de la empresa en la práctica.</li></ul> |
| Las personas cuentan con orientación suficiente y detallada sobre la seguridad de la información y se les anima a participar y afrontar los retos de la situación actual de la seguridad de la información. | <ul style="list-style-type: none"><li>• La ciberseguridad es un proceso de transformación con desafíos habituales desde todas las partes de la empresa.</li><li>• La orientación sobre ciberseguridad es simple, va al grano y se refiere a los típicos riesgos del día a día.</li><li>• El estado en relación con la ciberseguridad se evalúa constantemente de forma conjunta por los usuarios y los directores de seguridad.</li></ul>                                                                                              |
| Todo el mundo es responsable de la protección de la información dentro de la empresa.                                                                                                                       | <ul style="list-style-type: none"><li>• Los gerentes de seguridad y los usuarios comparten la responsabilidad en la ciberseguridad. Esto incluye tanto el ámbito del negocio, como el de viajes y el doméstico.</li><li>• Los usuarios tienen un entendimiento claro de sus responsabilidades y actúan de forma responsable.</li><li>• La empresa actúa en un entorno tolerante a fallos y evita usar chivos expiatorios.</li></ul>                                                                                                    |



## 4.4 CULTURA, ÉTICA Y COMPORTAMIENTO

### •Modelo de comportamiento de COBIT 5

| Modelo de Comportamiento de COBIT 5                                                                                                                                                                                              | Aplicación a la Ciberseguridad                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Las partes interesadas son conscientes de cómo identificar y responder a las amenazas para la empresa.                                                                                                                           | <ul style="list-style-type: none"><li>• Todos los usuarios, independientemente de su nivel jerárquico en la empresa, son partes interesadas en la ciberseguridad.</li><li>• Los usuarios son suficientemente conscientes del riesgo, amenazas y vulnerabilidades asociadas con los ataques/violaciones de seguridad.</li><li>• La respuesta ante incidentes y amenazas se entiende correctamente, y se practica habitualmente y se audita.</li></ul>                              |
| La dirección sostiene y anticipa de forma proactiva las innovaciones en seguridad de la información y las comunica a la empresa. La empresa es receptiva a tener en cuenta y tratar nuevos retos en seguridad de la información. | <ul style="list-style-type: none"><li>• Los gerentes de seguridad y usuarios finales identifican, prueban y adoptan de forma cooperativa innovaciones en ciberseguridad.</li><li>• La dirección y los usuarios finales identifican y adoptan nuevos casos de negocio aplicables a la tecnología, prácticas de seguridad y otros tipos de valor añadido para la ciberseguridad.</li><li>• De manera explícita, la empresa desea estar a la vanguardia en ciberseguridad.</li></ul> |
| La dirección del negocio está comprometida en una colaboración multi-funcional continua para lograr programas de seguridad de la información efectivos y eficientes.                                                             | <ul style="list-style-type: none"><li>• Los programas de ciberseguridad están implantados y forman parte de la estrategia global de innovación. Las innovaciones en seguridad se incorporan como proyectos claves.</li><li>• Las funciones del negocio cooperan con la seguridad de la información para maximizar la eficiencia y eficacia de la ciberseguridad.</li></ul>                                                                                                        |
| La dirección ejecutiva reconoce el valor de negocio de la seguridad de la información.                                                                                                                                           | <ul style="list-style-type: none"><li>• La dirección ejecutiva actúa como usuarios finales y reconoce el valor de la ciberseguridad. Participa activamente en las actividades de formación y concienciación.</li></ul>                                                                                                                                                                                                                                                            |

## 4.5 INFORMACIÓN

❑ Proteger la información sensible requiere una clasificación de activos de información y datos existentes que debe ser realizada como un todo en la gestión de la seguridad de la información:

- Paso 1. Categorizar la información. Identificar información sujeta a medidas de protección específicas como opuesta a la información ya cubierta por otras medidas de seguridad.
- Paso 2. Identificar que se hace con la información: almacenamiento, procesamiento, creación, compartición, eliminación.
- Paso 3. Determinar la sensibilidad de la transacción.
- Paso 4. Analizar la protección proporcionada por los controles aplicados previamente.
- Paso 5. Determinar los requerimientos de controles adicionales.
- Paso 6. Desarrollar e implementar un plan de acción para los controles adicionales.

## 4.6 SERVICIOS, INFRAESTRUCTURA Y APLICACIONES

❑ El catalizador de Servicios, Infraestructura y Aplicaciones identifica las capacidades de servicio, atributos y metas de la gestión de la seguridad de la información:

- Arquitectura de seguridad
- Concienciación en seguridad
- Desarrollo seguro
- Evaluaciones de seguridad
- Sistemas asegurados y configurados de forma adecuada
- Acceso y derechos de acceso de los usuarios de acuerdo a los requisitos del negocio
- Protección adecuada ante software malicioso, ataques externos e intentos de intrusión
- Respuesta adecuada ante incidentes
- Pruebas de seguridad
- Servicio de supervisión y alerta para los eventos relacionados con la seguridad

## 4.7 PERSONAS, HABILIDADES Y COMPETENCIAS

### ■ Habilidades de Ciberseguridad para Responsables y Usuarios Finales

| Conjunto de Habilidades/Experiencia | Responsable/Especialista de Ciberseguridad                                                                                                                       | Usuario Final                                                                                                                             |
|-------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| Gobierno                            | Amplia habilidad y experiencia, específicamente en las dimensiones sociales y de comportamiento                                                                  | Concienciación                                                                                                                            |
| Formulación de la estrategia        | Habilidad para formular componentes estratégicos de ciberseguridad y requerimientos estratégicos, entre ellos los casos de negocio                               | Concienciación y capacidad de entender (aceptar) la estrategia                                                                            |
| Gestión del riesgo                  | Fuertes habilidades en la evaluación y análisis de riesgos, así como opciones de tratamiento del riesgo                                                          | Reconocimiento de los riesgos de ciberdelincuencia y ciberguerra; conocimientos sobre cómo comportarse para evitar el riesgo y atenuarlo  |
| Desarrollo de la arquitectura       | Amplias habilidades en arquitectura técnica, experiencia superior a la media en tecnologías críticas                                                             | Conocimientos básicos de la tecnología en riesgo y del riesgo inherente de los dispositivos de usuario final                              |
| Operaciones                         | Profundas habilidades y experiencia en la operación de TI y procesos relacionados con la seguridad, cubriendo la empresa de extremo a extremo                    | Experiencia operando dispositivos de seguridad, aplicaciones y servicios críticos                                                         |
| Evaluación, pruebas y cumplimiento  | Habilidad para realizar evaluaciones de soporte, habilidades para pruebas exhaustivas, concienciación y profundo entendimiento de los requisitos de cumplimiento | Concienciación sobre los requerimientos de cumplimiento; comprensión básica de las evaluaciones; capacidad para participar en las pruebas |

## 5. SEPARAR EL GOBIERNO DE LA GESTIÓN

### •Principio 5: Separar el gobierno de la gestión

❑ El marco de COBIT 5 plasma una distinción muy clara entre el Gobierno y la Gestión ya que estos realizan funciones muy diferentes:

- ❑ Gobierno en la mayoría de las organizaciones el Gobierno es responsabilidad de la Junta Directiva bajo el liderazgo de su Presidente.
- ❑ Gestión en la mayoría de las organizaciones, la Gestión es responsabilidad de la Gerencia Ejecutiva, bajo el liderazgo del Gerente General (CEO).



## 5. SEPARAR EL GOBIERNO DE LA GESTIÓN

### • Principio 5: Separar el gobierno de la Gestión

- El Gobierno

El Gobierno asegura que se evalúan las necesidades, condiciones y opciones de las partes interesadas para determinar que se alcanzan las metas corporativas equilibradas y acordadas; estableciendo la dirección a través de la priorización y la toma de decisiones; y midiendo el rendimiento y el cumplimiento respecto a la dirección y metas acordadas.

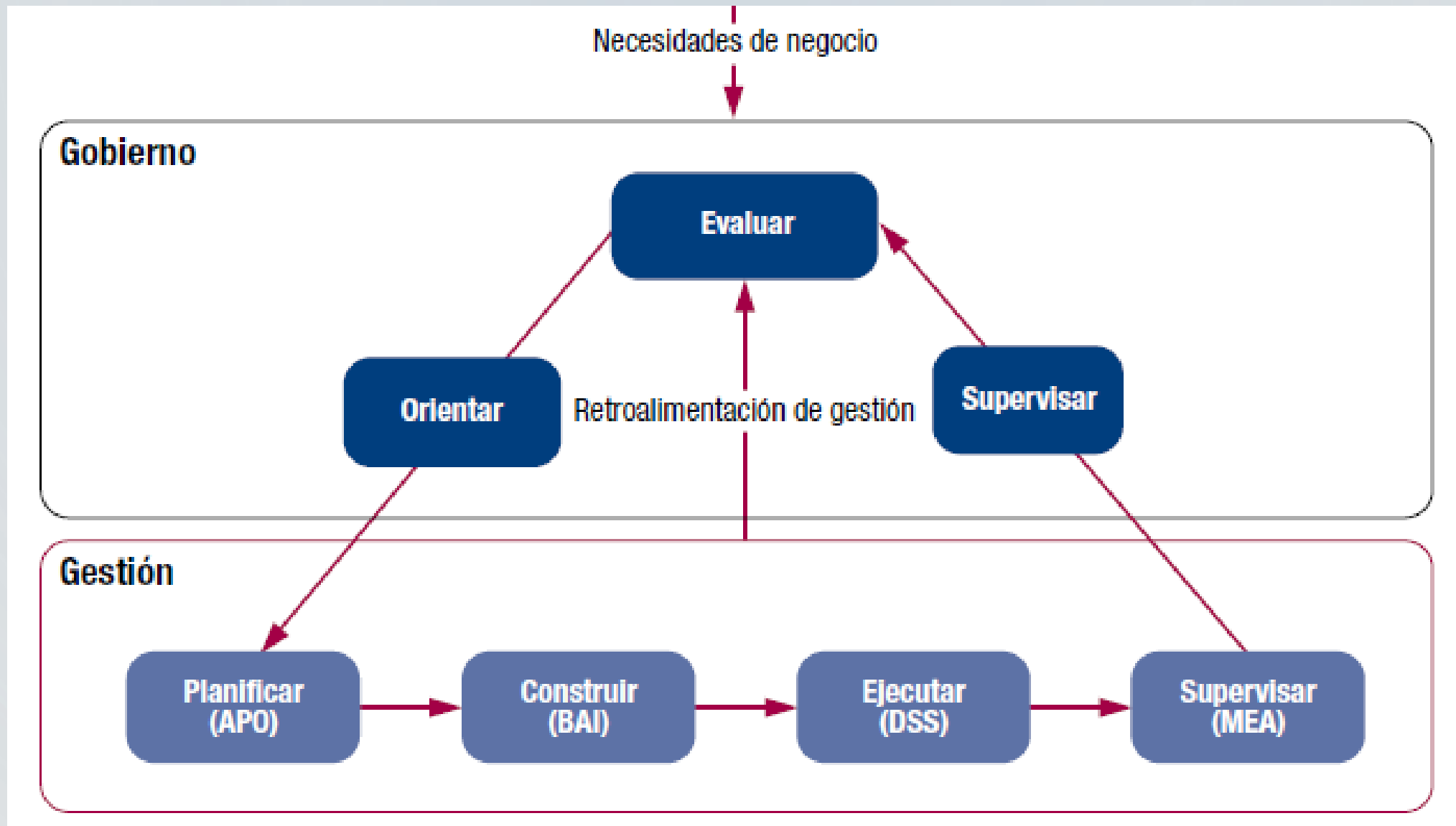
- Gestión

La gestión planifica, construye, ejecuta y controla actividades alineadas con la dirección establecida por el cuerpo de gobierno para alcanzar las metas empresariales.



## 5. SEPARAR EL GOBIERNO DE LA GESTIÓN

- Principio 5: Separar el gobierno de la Gestión



## 5. SEPARAR EL GOBIERNO DE LA GESTIÓN

### •Principio 5: Separar el gobierno de la gestión

- ☐ El marco de COBIT 5 describe siete categorías de habilitadores. Los procesos constituyen una categoría.
- ☐ Una compañía puede organizar sus procesos como estime conveniente, siempre y cuando queden cubiertos todos los objetivos necesarios de gobierno y Gestión.
- ☐ Las compañías más pequeñas podrán tener menos procesos,
- ☐ Las compañías más grandes y más complejas podrán tener muchos procesos, todos para cubrir los mismos objetivos.
- ☐ COBIT 5 incluye un Modelo de Referencia de Procesos (PRM), que define y describe en detalle un número de procesos de Gestión y de gobierno.

## 6. EJEMPLO DE METAS Y OBJETIVOS

### ❏ Ejemplo de Metas

❖ Una empresa ha definido una cantidad de metas corporativas para sí misma, entre las que la satisfacción del cliente es la más importante. A partir de aquí, quiere conocer todos los aspectos relativos a Ti que necesita mejorar.

- Cultura de servicio orientada al cliente
- Continuidad y disponibilidad del servicio del negocio
- Respuestas ágiles a un entorno de negocios cambiante

## 6. EJEMPLO DE METAS Y OBJETIVOS

### □ Ejemplo de Metas

- A partir de ahí, se sugieren como más importantes las siguientes metas relacionadas con TI como una cuestión de prioridad
  - Alineamiento de TI y la estrategia del negocio
  - Gestión de los Riesgos de negocio de acuerdo con las TI gestionados
  - Entrega de servicios de TI en línea con los requisitos del negocio
  - Agilidad de TI
  - Seguridad de la información, infraestructuras de procesamiento y aplicaciones
  - Disponibilidad de información útil y relevante para la toma de decisiones
  - Conocimiento, experiencia e iniciativas para la innovación en el negocio
- Cuando se completa este ejercicio, la empresa cuenta con un conjunto de objetivos consistentes para cada catalizador que le ayudará a alcanzar los objetivos estratégicos definidos y un conjunto de métricas asociadas para medir el rendimiento.

PREGUNTAS





GRACIAS POR SU ATENCIÓN